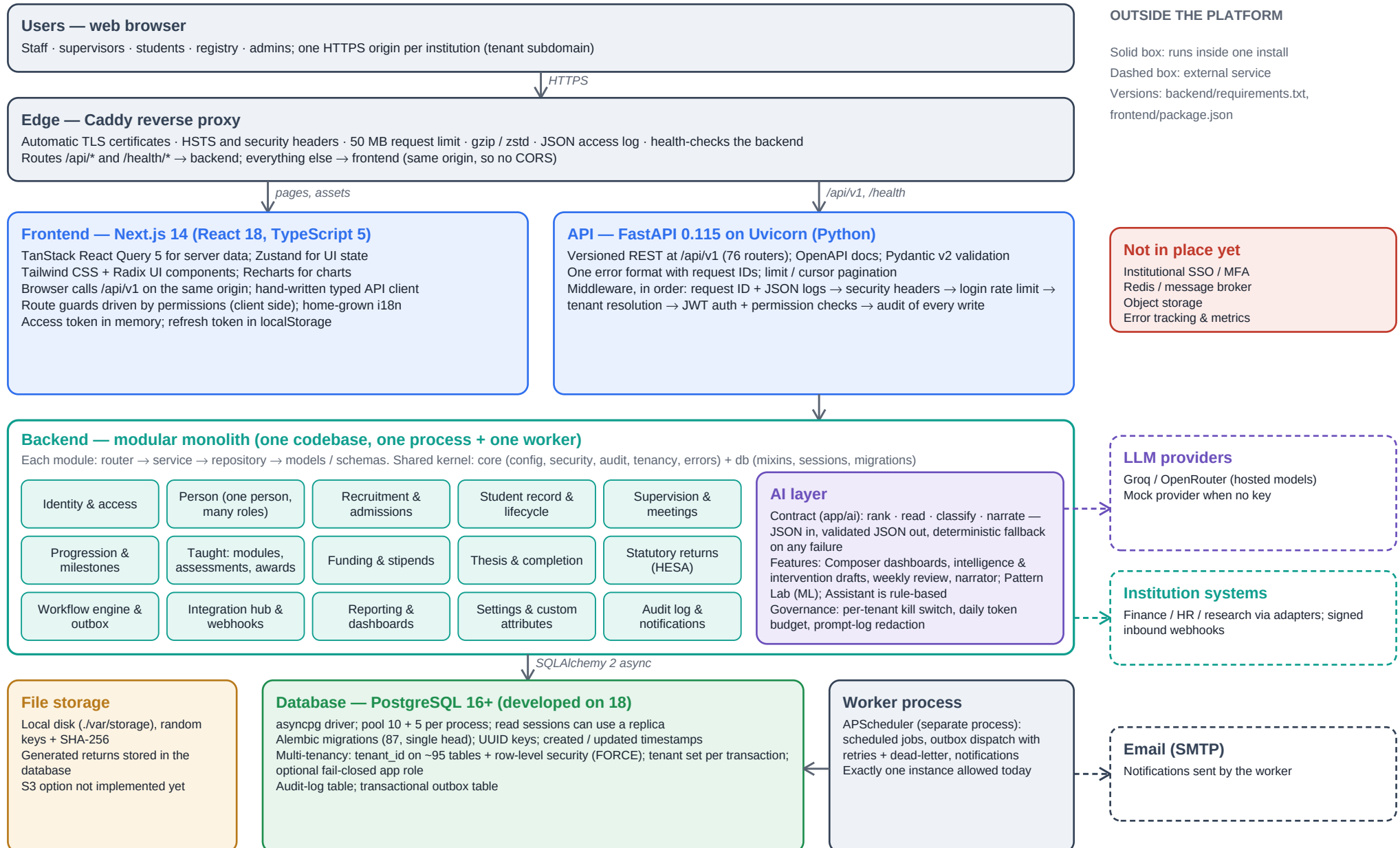
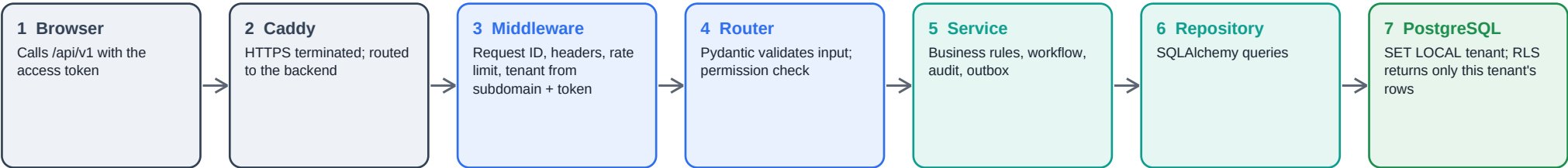


Current tech stack



How a request flows



Stack by layer

Layer	Technology	Version	Role
Edge	Caddy	—	HTTPS with automatic certificates, security headers, routing, request size limit
Frontend	Next.js, React, TypeScript	14.2 / 18.2 / 5.3	Web application (server-rendered pages + browser app)
	TanStack React Query, Zustand	5.62 / 4.5	Server data fetching and caching; UI state
	Tailwind CSS, Radix UI, Recharts	3.4 / 1.1 / 2.15	Styling, accessible components, charts
API	FastAPI on Uvicorn	0.115 / 0.34	REST API at /api/v1, OpenAPI docs, middleware chain
	Pydantic, pydantic-settings	2.10 / 2.7	Request / response validation; configuration from environment
Backend	Python	3.13 (local)	Modular monolith: domain modules + shared kernel
	APScheduler	3.11	Worker: scheduled jobs, outbox dispatch, notifications
	httpx	0.28	Outbound calls to integration adapters and LLM providers
Data access	SQLAlchemy (async), asyncpg, Alembic	2.0 / 0.30 / 1.14	ORM, PostgreSQL driver, schema migrations
Database	PostgreSQL	16+ (18 in dev)	System of record; row-level security for tenant isolation
Security	python-jose, passlib	3.3 / 1.7	JWT (HS256) signing; password hashing (PBKDF2-SHA256)
AI	Groq SDK / OpenRouter over HTTP	0.13	Hosted LLMs behind the app/ai contract; mock when unset
Tests	pytest + httpx	575 tests	Unit, integration and one end-to-end lifecycle test

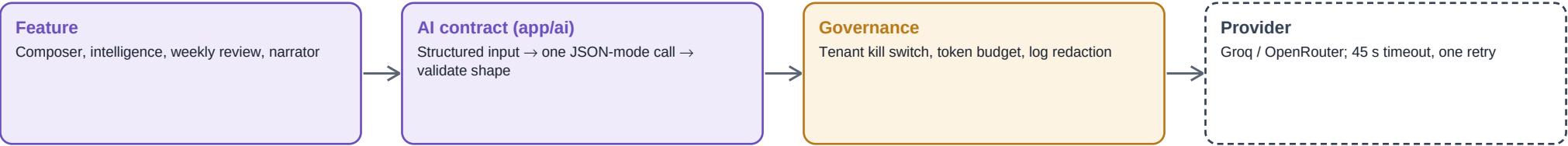
Security by layer

What protects each layer today, and what isn't in place yet. The gaps are detailed in [docs/approach/production-readiness/Production_Readiness_Architecture_Questions.pdf](#).

Layer	In place	Not yet
Network edge	HTTPS with automatic certificates; HSTS; nosniff / frame / referrer headers; 50 MB request limit	No web application firewall
Browser	Access token held in memory only; permission-driven route guards; same origin (no CORS surface)	Refresh token in localStorage; no Content-Security-Policy; route guards client-side only
API	Pydantic validation on every request; security headers; login and password-reset rate limit; request IDs; one error format	Rate limit in memory per process; API docs public
Identity	JWT access tokens (15 min); refresh tokens stored server-side, revocable, rotated on every use; PBKDF2 password hashing; lockout after 5 failures	No MFA; no SSO; HS256 with one shared secret whose default isn't blocked
Authorisation	Permission codes checked on every endpoint; row scoping by role (all / supervisor / self)	Row scoping by fixed role lists, not configurable
Tenant isolation	tenant_id on ~95 tables; PostgreSQL row-level security with FORCE; tenant set per transaction; subdomain mismatch returns 403; fail-closed role available	Fail-closed role optional; tenant_id not yet NOT NULL; RLS not on users table
Data	Audit log of every write; transactional outbox; signed inbound webhooks (HMAC)	No encryption at rest configured; no field-level encryption; no automated backups
AI	Per-tenant kill switch; daily token budget; prompts redacted in logs; human approval on AI-drafted actions; deterministic fallback	Real names sent to third-party providers; AI calls not persisted for audit
Operations	JSON logs with request IDs; health endpoints	Secrets in .env files; no error tracking / metrics; no CI security scanning

AI layer

Principle in the code: **the deterministic core decides; the model narrates**. Every AI function takes structured input, makes one JSON-mode call, validates the reply, and falls back to a deterministic answer on any failure.



Any failure (no key, timeout, bad JSON, out-of-set answer) → deterministic fallback. The feature still works with the model switched off (tested).

AI feature	What the AI does	Who decides
Composer	Builds read-only dashboard layouts from a question	User views; nothing is written
Intelligence & interventions	Drafts intervention plans for at-risk students	A person with student.write confirms each action
Weekly review queue	Ranks and summarises students needing attention	Staff review the queue
Student narrator	Describes a student's position in plain language	Information only
HESA advisory ingest	Drafts spec changes from an uploaded directive	A registry owner accepts the diff
Pattern Lab	Trains and scores ML models (not an LLM)	Promotion needs ml.approve
Assistant (Ask PGR)	Rule-based; no LLM in use	—